SEMANTIC GRAVITY

Unified Risk Intelligence Platform

Solution Blueprint v3.0

Prepared for: Royal Enfield

Prepared by: Semantic Gravity

May 2026 | Classification: Confidential

1. Executive Summary

Royal Enfield currently manages cybersecurity risk across 9 disparate sources — manually consolidated into an Excel risk register with no SLA tracking, no auto-assignment, and no remediation guidance per finding. This blueprint proposes URIP — a Unified Risk Intelligence Platform that aggregates all risk feeds, applies exploitability-first prioritization, auto-assigns with pending day tracking, and delivers remediation steps for every single risk.

URIP does not replace existing security tools. It is an orchestration and intelligence layer on top of the existing stack — with a clear path to full auto-remediation in Phase 2.

KEY ENVIRONMENT — ROYAL ENFIELD

Security Tool Stack	CrowdStrike, Forescout NAC, Cisco ISE, CyberArk PAM, Zscaler ZTA/ZIA/CASB, Fortiguard, Google Workspace, Armis (OT)
Risk Sources	14 — 9 core risk inputs + 5 security tool connectors
Risk Scoring	CVSS v4.0 (client current). URIP adds EPSS + KEV + Asset Criticality composite layer
Current Tracking	Manual Excel — no pending days tracking, no remediation steps, no auto-assignment
Key Requirement	Every risk must show: Raised Date + Pending Days + Remediation Steps

2. Problem Statement

Problem 1	Multiple risk sources in separate consoles — no unified view. Teams spend hours consolidating manually.
Problem 2	All risks in Excel — no pending days counter, no raised date tracking, no auto-assignment.
Problem 3	Risk accepted — no recommendation given, still counts in board reports. Reports inflated.
Problem 4	Low-impact vulnerabilities fixed first. Zero-Days wait. No exploitability-based prioritization.
Problem 5	No remediation steps per finding — IT team has to research fixes manually for every risk.
Problem 6	Managed and unmanaged assets treated the same — no visibility into shadow IT exposure.

3. Intelligence & Enrichment Engine

Complete intelligence pipeline — from raw input to prioritized, enriched, remediation-ready output. Defined once here, referenced throughout.

3.1 Core Workflow

DETECT → NORMALIZE → DEDUPLICATE → ENRICH → SCORE → ASSIGN → REMEDIATE → REPORT

DETECT	Pull live feeds from all 14 sources via API connectors and file uploads
NORMALIZE	Convert all severity formats to unified CVSS-equivalent 0-10 scale (Section 3.3)
DEDUPLICATE	Asset fingerprinting merges duplicate findings across sources (Section 3.4)
ENRICH	Apply EPSS + KEV + Asset Criticality + APT tags + IOC matching (Section 3.5)
SCORE	Compute composite score + SSVC label + Raised Date + Pending Days counter starts
ASSIGN	Auto-assign to product owner/SPOC per domain. Pending days counter visible immediately.
REMEDIATE	Attach remediation steps from NVD/vendor advisory/playbook to every risk row
REPORT	Dashboard + board report + CERT-In compliance — accepted risks excluded

3.2 14 Data Source Connectors

#	Source	Tool (RE Stack)	Data Type	Integration
CORE 9 — Primary Risk Sources (Client Requested)				
1	Spotlight (VM)	CrowdStrike Falcon	CVEs, endpoints	REST API
2	EASM	CrowdStrike / External	External attack surface	REST API
3	CNAPP	CrowdStrike Cloud	Cloud misconfigs	REST API
4	OT Environment	Armis	OT asset vulns	Armis API
5	VAPT Reports	External Vendor	Pentest findings	Portal / File Upload
6	Threat Intelligence	External Feed	Active exploit intel	Feed / API
7	CERT-In Advisories	CERT-In Portal	Govt advisories	RSS / Manual
8	Bug Bounty	Internal/External	Researcher findings	Webhook / Upload
9	SoC Alerts	SIEM / SoC Team	Live incident alerts	SIEM API / Webhook
EXTENDED 5 — Security Tool Stack (Semantic Gravity Value-Add)				
10	Network Access Control	Forescout NAC / Cisco ISE	Rogue devices, NAC alerts	Syslog / API

11	Privileged Access Risk	CyberArk PAM	Shared credentials	REST API
12	Cloud Access / Shadow IT	Zscaler ZTA / CASB	Unauthorized apps	Zscaler API
13	Firewall Threat Events	Fortiguard Firewall	Blocked threats	Syslog
14	Email Security	Google Workspace	Phishing, BEC alerts	Google API

3.3 Managed vs Unmanaged Assets

Not all assets in Royal Enfield's environment are known or controlled by the IT team. URIP distinguishes between managed and unmanaged assets to surface shadow IT risk.

Type	Definition	How URIP Identifies
Managed	Assets registered in CrowdStrike + ServiceNow CMDB. IT team knows they exist and controls them.	CrowdStrike agent present + CMDB record exists. Asset tag: MANAGED.
Unmanaged	Assets on the network NOT in CMDB. Shadow IT — personal devices, rogue servers, forgotten VMs.	Forescout NAC / Armis detects device. No CMDB record. Asset tag: UNMANAGED — HIGH RISK.
Unknown External	Subdomains and IPs exposed to internet that IT team may not know about.	EASM scan discovers. Not in known asset list. Asset tag: UNKNOWN EXTERNAL — INVESTIGATE.

IP Mapping	Every asset shows Internal IP + External/Public IP side by side. Critical for understanding true attack surface.
Product Owner	Each asset linked to a named product owner — not just a team. Accountability at individual level.
Probe to Collect Evidence	URIP actively probes registered assets (with permission) to collect live risk evidence — open ports, running services, SSL status.

3.4 Normalization Engine

Not all 14 sources use CVSS. URIP normalizes every finding to a 0-10 CVSS-equivalent scale before scoring.

Source	Native Format	Mapping Method	Example
CrowdStrike (Spotlight/EASM/CNAPP)	ExPRT 0-100	Divide by 10	ExPRT 85 → 8.5
Armis (OT)	0-10 or 0-100	Normalize to 0-10	Armis 7.5 → 7.5
VAPT Reports	CVSS 0-10	Use directly	CVSS 8.5 → 8.5
CERT-In Advisories	Critical/High/ Medium/Low	Rule map	Critical → 9.0
Bug Bounty	P1/P2/P3/P4	Heuristic model (3-step waterfall)	P1 → 9.0 base
SoC Alerts	Critical/High/ Medium/Low	Rule map	High → 7.5

3.5 De-duplication — Asset Fingerprinting

```
Asset Identity = MAC Address + Hostname + IP Address (composite key)

EXAMPLE: CrowdStrike reports 'Log4j High' on 192.168.1.50 (SAP-PRD-01)
         VAPT report says 'CVE-2021-44228 Critical' on SAP-PRD-01
         → URIP matches: same CVE + same asset fingerprint → MERGED
         → Highest composite score retained. Both sources attributed.

OT NETWORK: Armis in isolated segment → On-Premise Collector or Secure API
Gateway
```

3.6 Composite Scoring Formula

FINAL FORMULA — Codex + Kimi Consensus (Additive Model)

```
composite = max(0.0, min(10.0,  0.55×CVSS  +  2.5×EPSS  +  KEV_bonus
+  asset_bonus))

KEV_bonus   = +2.0  (CVE confirmed in CISA KEV — active exploitation
confirmed)
asset_bonus = +1.0 Tier 1  |  +0.5 Tier 2  |  0.0 Tier 3  |  -0.5 Tier 4
EPSS        = FIRST.org live daily  |  fallback: Crit=0.30 High=0.20 Med=0.10
Low=0.05
max(0.0,...) floor prevents negative scores on Tier 4 findings
```

3.7 Advisory Applicability Check

Not all CERT-In and threat intel advisories are relevant at time of review. URIP automatically classifies each advisory as Valid or Expired based on patch release date and CVE status.

Valid Advisory	CVE still unpatched on affected asset + no vendor fix available yet. Risk stays OPEN.
Patch Available	Vendor patch released. URIP fetches patch details from NVD/vendor API. Remediation steps auto-populated.
Expired Advisory	Patch applied and verified, or CVE not applicable to asset version. Risk auto-closed with audit trail.
Redundant Advisory	Duplicate of existing open risk. Merged via de-duplication engine. Not double-counted.

Advisory source cross-referenced against: NVD patch database, vendor security bulletins (Microsoft, Cisco, Palo Alto), CERT-In resolution status.

3.8 Enrichment Layer — Live Status

#	Capability	Source	Status	On Risk Rows?	In Score?
1	EPSS	FIRST.org API	✅ **LIVE**	✅ Yes	✅ Yes (2.5×)
2	CISA KEV	CISA JSON	✅ **LIVE**	✅ Yes	✅ Yes (+2.0)
3	Asset Criticality	CrowdStrike+CMDB	✅ **LIVE**	✅ Yes	✅ Yes (+1.0 to -0.5)
4	APT Tags (MITRE)	MITRE ATT&CK JSON	✅ **LIVE/WIRED**	✅ Yes	❌ Context only
5	IOC Matching	OTX indicators	✅ **LIVE/WIRED**	✅ Auto-creates Critical	❌ Score 10.0 on match
6	Remediation Steps	NVD + Vendor APIs	✅ **LIVE**	✅ Every risk row	❌ Not scored
7	Geo Threat Map	OTX + MaxMind	✅ **LIVE**	⚠️ Separate page	❌ Context
8	Dark Web Monitor	Simulated data	⚠️ **SIMULATED**	⚠️ Dashboard KPI	❌ Context
9	RE Network Logs	Client SIEM	❌ **POST GO-LIVE**	❌ Needs SIEM	❌ Future

4. Remediation Engine

Every risk in URIP carries remediation steps — automatically fetched and attached at ingestion time. IT teams do not need to research fixes manually. Phase 2 extends this to automated script execution.

4.1 Remediation Steps — Per Risk

Every risk row in the register shows actionable remediation steps. Source depends on finding type.

Source	Remediation From	Example
CVE Findings (any source)	NVD advisory + vendor patch notes auto-fetched via NVD API	CVE-2023-29357 → 'Apply MS patch KB5002099. Disable anonymous SharePoint access. Enable MFA.'
CERT-In Advisory	Advisory text parsed — action items extracted	CERT-In CIVN-2026-1234 → 'Update OpenSSL to 3.1.4. Restart affected services. Verify with openssl version.'
VAPT Reports	Vendor recommendation in report — imported with finding	Researcher writes: 'Sanitize user input on /api/upload endpoint. Implement file type whitelist.'
Bug Bounty	Researcher recommendation — part of submission form	P1 submission includes: 'Fix IDOR on /api/users/{id} — add authorization check before returning user data.'
SoC Alerts	Playbook-based rule map — predefined per alert type	Rogue device alert → 'Isolate device via Forescout. Identify owner. Verify device registration or remove.'
IOC Match (IP/Hash)	IOC context from OTX — standard response playbook	Malicious IP match → 'Block IP at Fortiguard. Revoke any active sessions. Check lateral movement in logs.'
SSL Expired	Fixed text remediation	'Renew SSL certificate. Update A records if needed. Verify via SSL Labs after renewal.'
Missing DMARC	Fixed text remediation	'Add DMARC TXT record to DNS: v=DMARC1; p=quarantine; rua=mailto:admin@royalenfield.com'

4.2 Auto-Remediation — Phase 2

Phase 1 delivers remediation steps per risk. Phase 2 activates automated script execution — URIP pushes the fix to the affected system without human intervention.

AUTO-REMEDIATION PIPELINE — Phase 2

```
Risk Registered → Patch Available? (NVD API check)
  → YES: Remediation script selected from playbook library
         Script pushed to affected system via:
           CrowdStrike RTR (Real Time Response) — endpoint patches
           Ansible playbook — server configuration fixes
           Fortiguard API — firewall rule updates
           CyberArk — credential rotation
  → Implication check: What services will restart? Any downtime?
```

```
  → Approval gate: Auto-execute OR require SPOC approval (configurable)
  → Execution logged: Timestamp + executor + output + before/after state
  → Re-test: URIP re-scans asset post-execution to confirm fix
  → Risk closed automatically if re-test passes
  → NO: Risk stays OPEN. Manual remediation steps shown. Pending days counter
running.
```

Script Execution Scope	Configurable per risk type. CISO defines which categories auto-execute vs require approval.
Implication Check	Before any script runs — URIP shows: affected services, expected downtime, rollback plan. No surprises.
Internal ↔ External IP	Script targets internal IP of asset. External IP used for re-test verification via external scanner.
BitSight Integration (Future)	Post-remediation, BitSight score change tracked. Shows security posture improvement over time.
Audit Trail	Every automated action logged — who approved, what ran, what changed, re-test result.

5. Operational Integration

5.1 Jira / ServiceNow Integration

Trigger	Risk assigned in URIP → Jira/ServiceNow ticket auto-created immediately
Ticket Contents	CVE ID, composite score, SSVC, asset, tier, APT context, Raised Date, Pending Days, full remediation steps
Bi-directional	Ticket closed in Jira → URIP risk auto-updated to Resolved. No manual sync.
Closure Rule	Risk closes only when remediation verified + evidence uploaded OR auto-remediation re-test passes

5.2 Raised Date + Pending Days (Replaces SLA)

Royal Enfield's priority is tracking how long a risk has been open — not a fixed SLA deadline. URIP tracks Raised Date and auto-calculates Pending Days in real time.

```
Raised Date  = Date risk first detected and registered in URIP
Pending Days = Today - Raised Date (auto-calculated, live counter)

EXAMPLE RISK ROW:
  RE-003 | SharePoint Privilege Escalation | Raised: Apr 5, 2026 | Pending: 8
days | Status: Open

ESCALATION RULES (configurable):
  Critical findings: Alert at 3 days pending. Escalate to CISO at 7 days.
  High findings:    Alert at 7 days pending. Escalate to HoD at 14 days.
  Medium findings:  Alert at 30 days pending.
  Low findings:     Alert at 90 days pending.
```

5.3 OT Network Access

Challenge	Armis OT data in isolated network segment — not reachable from corporate network
Solution A	On-Premise Collector: Lightweight agent inside OT segment. Sends encrypted summary to URIP.
Solution B	Secure API Gateway: Proxy in DMZ. Armis pushes to proxy. URIP pulls from proxy.
Security	Neither option exposes OT network to internet. All transit encrypted (TLS 1.3).

5.4 API Rate Limits

Zscaler CASB	Batched polling (15-min intervals). Token refresh automatic.
CrowdStrike API	OAuth 2.0. Exponential backoff on 429 responses.
FIRST.org (EPSS)	Batch 100 CVEs per call. 24-hour in-memory cache. ~95% call reduction.
CISA KEV	Full catalog downloaded once per 24 hours. In-memory hash set for instant lookups.

6. Portal Modules

6.1 Security Posture Dashboard

- Overall security posture score — aggregated composite across all 14 sources + asset management status
- Managed vs Unmanaged asset count — how much of the environment is visible and controlled
- BitSight-style posture grade (A/B/C/D/F) — executive-friendly single number (Phase 2 with BitSight integration)
- Breakdown by domain: Endpoint, Cloud, Network, Application, Identity, OT
- Risk trend: posture improving or degrading week over week
- Critical & High count with pending days alert — how many are overdue
- Role-based views: CISO, IT Team, Executive/Board

6.2 Risk Register — Full Column Set

Replaces Excel. Auto-populated from all 14 sources. Every row has remediation steps attached.

Column	Type	Description
Risk ID	**Auto**	RE-001, RE-002... sequential per org
Finding Title	**Auto**	CVE name or finding description
Source	**Auto**	Which of 14 sources detected it
CVE ID	**Auto**	CVE number if applicable
CVSS Score	**Auto**	Raw base score 0-10
EPSS Score	**Auto**	Exploit probability 0-1 (live)
KEV Status	**Auto**	Yes (CISA confirmed) / No
Composite Score	**Auto**	Final prioritized score 0-10
SSVC Label	**Auto**	ACT NOW / ACT / ATTEND / TRACK
Severity	**Auto**	Critical / High / Medium / Low
Asset	**Auto**	Hostname + Internal IP + External IP
Asset Type	**Auto**	Managed / Unmanaged / Unknown External
Asset Tier	**Auto/Manual**	Tier 1-4 (CrowdStrike tag or keyword)
Domain	**Auto**	Application / Network / Cloud / OT / Identity
Product Owner	**Manual**	Named individual responsible for this asset
Owner Team	**Auto**	Team assigned based on domain
APT Tags	**Auto**	Which APT groups use this CVE
Exploit Status	**Auto**	Weaponized / Active / PoC / None
Advisory Status	**Auto**	Valid / Patch Available / Expired / Redundant
Raised Date	**Auto**	Date risk first detected in URIP
Pending Days	**Auto**	Live counter: today minus raised date
Status	**Manual**	Open / In Progress / Resolved / Accepted
Remediation Steps	**Auto**	Step-by-step fix from NVD/vendor/playbook
Jira Ticket	**Auto**	Auto-created ticket ID + link

Evidence	**Upload**	Patch screenshot, config proof, re-test report

6.3 Risk Detail Card — Per Finding

Every risk has a full detail view. This is what IT team sees when they open a finding.

```
RE-003  |  SharePoint Privilege Escalation

FINDING:     CVE-2023-29357 — SharePoint Server Privilege Escalation
DESCRIPTION: Detected by EASM connector. Dealer Portal
api.dealers.royalenfield.com.
             Requires immediate triage. EPSS 100th percentile.

SOURCE:      EASM                 DOMAIN:         Application
CVSS SCORE:  9.8                  COMPOSITE SCORE: 10.0
SEVERITY:    Critical              EPSS SCORE:      0.94356
EPSS %ile:   100th percentile     IN KEV CATALOG:  Yes (CISA KEV)
EXPLOIT:     Weaponized           ASSET:           Dealer Portal
api.dealers.royalenfield.com
ASSET TYPE:  Managed              INTERNAL IP:     10.0.14.23
EXTERNAL IP: 203.45.67.89         PRODUCT OWNER:   Rajesh Kumar (App Team
Lead)
APT TAGS:    APT28, APT41         TTP:             T1190 (Exploit Public-
Facing App)
RAISED DATE: Apr 5, 2026         PENDING DAYS:    8 days ⚠️
STATUS:      Open                 JIRA TICKET:     RE-URIP-2341

REMEDIATION STEPS:
  1. Apply Microsoft patch KB5002099 (SharePoint Server 2019 CU)
  2. Disable anonymous access on SharePoint site collection settings
  3. Enable MFA for all SharePoint admin and editor accounts
  4. Review access logs for CVE-2023-29357 exploitation indicators
  5. Request VAPT vendor re-test after patch — sign off in portal

ADVISORY STATUS: Valid — Patch Available (KB5002099 released Jan 2024)
```

6.4 Risk Acceptance Workflow

- Owner flags risk for acceptance → system auto-generates Compensating Controls recommendation
- HoD approves with digital sign-off — full audit trail
- Accepted risks tagged — auto-excluded from all dashboards and board reports
- Re-review reminder at 90 days — HoD must re-approve or remediate

6.5 VAPT Vendor Portal

Vendor Login	Guest role assigned by Royal Enfield. Scoped — vendor sees only their own submissions.
Structured Entry	Form: Vulnerability name, CVE ID, CVSS, Affected Asset, Exploit

	Maturity, Remediation Recommendation, PoC evidence upload.
Auto-Processing	On submission: EPSS + KEV enrichment, remediation steps fetched, auto-assigned, Raised Date set, Pending Days starts.
Re-test Flow	IT fixes → 'Request Re-test' → Vendor notified → Pass/Fail with evidence → Auto-close on Pass

7. Demo — Sample Risk Register

Representative sample showing Raised Date + Pending Days + Remediation excerpt. All data illustrative.

ID	Finding	CVSS	Comp.	Raised	Pending	Remediation (excerpt)
RE-001	RCE — Public Web App (VAPT)	9.8	10.0	Apr 1	**12 days**	Apply vendor patch. WAF rule. Re-test required.
RE-002	Log4j — Production Server (Spotlight)	9.0	9.8	Apr 3	**10 days**	Update Log4j to 2.17.1. Restart services. Verify.
RE-003	SharePoint Priv. Escalation (EASM)	9.8	10.0	Apr 5	**8 days**	Apply KB5002099. Disable anon access. MFA on.
RE-004	Unencrypted OT Protocol (Armis)	8.5	9.3	Apr 6	**7 days**	Enable TLS on OT comms. Armis policy update.
RE-005	Shadow IT App — Zscaler	7.2	8.0	Apr 8	**5 days**	Block app in Zscaler CASB. Notify user. Log.
RE-006	CERT-In CVE-2026-1234	7.0	7.8	Apr 9	**4 days**	Update affected package. CERT-In resolution confirm.
RE-007	Shared Admin Password (CyberArk)	6.1	6.5	Apr 10	**3 days**	Rotate via CyberArk. Enable session isolation.
RE-008	IDOR — HR Portal (Bug Bounty)	5.4	5.9	Apr 11	**2 days**	Add authz check on /api/users/{id} endpoint.

8. Implementation Plan

Honest 6-month delivery schedule for a 7,000-endpoint enterprise environment with 14 sources.

Phase	Timeline	Deliverable	Milestone
Phase 1	Month 1	CrowdStrike + Armis connectors. OT network access (On-Prem Collector or Proxy). Asset fingerprinting. Managed/Unmanaged classification.	Core data flowing
Phase 2	Month 2	Risk register + composite scoring. Raised Date + Pending Days tracking. Remediation steps auto-fetch (NVD API). VAPT portal + file parser.	Register live with remediation
Phase 3	Month 3	Risk acceptance workflow. HoD approval. Jira/ServiceNow integration. Advisory applicability engine.	Full workflow live
Phase 4	Month 4	Executive dashboard. Security Posture score. Board + CERT-In reports. APT tagging + IOC matching. Role-based access.	Demo ready
Phase 5	Month 5	Remaining connectors. UAT with RE IT team. Auto-remediation scripts pilot (CrowdStrike RTR). Implication check engine.	Full system live
Phase 6	Month 6	Auto-remediation go-live. Performance testing. Ops team training. Handover.	Production + Auto-Remediation

9. Commercial Model

Model	1-time platform delivery + subscription support
Endpoint Tier	Priced per endpoint tier — covers Royal Enfield's current environment with headroom for growth
Subscription	2-year initial term, renewable annually
Includes	All 14 source connectors, portal, dashboards, reports, remediation engine, OTX + MITRE integrations
Auto-Remediation	Included in Phase 2 subscription — script library, implication checker, audit trail
Zero Extra Cost	OTX, MITRE ATT&CK, CISA KEV, EPSS, NVD — all free APIs. No additional licensing.
Paid Exception	BitSight integration (optional) + Dark web monitoring (SpyCloud/Recorded Future) — optional add-ons

10. What We Need From Royal Enfield

01 — Tool APIs	CrowdStrike read-only API key. Armis API credentials. Zscaler CASB API token. SoC SIEM webhook or API.
02 — OT Network	Network topology of Armis segment. Decision: On-Premise Collector or Secure API Gateway.
03 — CMDB / Tags	CrowdStrike asset criticality tags or ServiceNow CMDB Business Criticality field — for asset tiering.
04 — VAPT Sample	One sample VAPT report (PDF or Excel) — to finalize import parser and remediation extraction.
05 — Risk Logic	How do you rate Bug Bounty (P1/P2?), SoC alerts, CERT-In responses currently?
06 — Ticketing	Jira or ServiceNow? Project/board structure for vulnerability tickets?
07 — Owner Matrix	Product owner mapping per asset/domain — who is responsible for what?
08 — Competitor Quotes	Quotes from PFC and other vendors — for commercial benchmarking.

11. FAQ — Objection Handler

Q: We use CrowdStrike which already scores vulnerabilities. Why URIP?

CrowdStrike's ExPRT scoring is excellent — for CrowdStrike findings only. Your VAPT reports, CERT-In advisories, Bug Bounty findings, and SoC alerts are not scored by CrowdStrike. URIP takes CrowdStrike's score, normalizes it to the same scale as all other sources, and gives one unified register with pending days + remediation steps across all 14 inputs.

Q: How does URIP handle the same vulnerability found by two tools?

Asset Fingerprinting — MAC Address + Hostname + IP. Same CVE on same asset from two sources = merged into one finding. Highest composite score retained. Both sources attributed. Remediation steps combined.

Q: How does auto-remediation work without breaking production?

Before any script executes, URIP runs an Implication Check — shows which services will restart, expected downtime, and rollback plan. CISO configures which risk categories auto-execute vs require SPOC approval. All actions logged with before/after state. Re-test runs automatically after execution.

Q: How does Armis OT data reach URIP if it is on a separate network?

Two options: (A) On-Premise Collector — lightweight agent inside OT segment, sends encrypted summary to URIP. (B) Secure API Gateway — proxy in DMZ between OT and URIP. Neither option exposes the OT network directly to the internet. All data encrypted TLS 1.3.

Q: The timeline is 6 months — is that realistic?

Yes. Core portal and scoring engine are already built. Months 1-3 connect your specific tool stack and validate data quality. Months 4-6 are integration hardening, UAT, and go-live. Auto-remediation pilots in Month 5 with full go-live in Month 6. Realistic for a 7,000-endpoint environment with 14 sources.

12. Recommended Enhancements

12.1 Threat Map — Word Cloud Visualization

Word Cloud 1	Most active Threat Actors targeting client sector. Size = frequency. Example: APT28, APT41, Lazarus.
Word Cloud 2	Top Attack Techniques in current threat pulses. Example: Phishing, RCE, Credential Theft, Supply Chain.
Word Cloud 3	Most targeted sectors. Example: Manufacturing, Defense, Energy, Automotive, Government.
Demo Impact	High — board-level visual. WHO is attacking, HOW they attack, WHO ELSE they target. One glance.
Implementation	Data from MITRE + OTX. D3.js word cloud plugin. Estimated effort: 1-2 days.
Status	Recommended — not yet implemented. Proposed for next sprint post demo feedback.

Appendix — Glossary of Key Terms

Quick reference for all abbreviations used in this document and the Gurgaon demo.

GROUP 1 — SCORING

Term	Full Name	Managed By	Simple Function
CVE	Common Vulnerabilities & Exposures	MITRE	The ID Number for a bug. Every vulnerability has a unique name.
CVSS	Common Vulnerability Scoring System	FIRST.org	The Size of the hole. Score 0-10. 10 = giant hole.
EPSS	Exploit Prediction Scoring System	FIRST.org	Probability a CVE will be exploited in next 30 days.
KEV	Known Exploited Vulnerabilities	CISA	Confirmed list of CVEs actively used by attackers right now.
SSVC	Stakeholder-Specific Vulnerability Categorization	CISA/SEI	Decision label: ACT NOW / ACT / ATTEND / TRACK.

GROUP 2 — THREATS

Term	Full Name	Managed By	Simple Function
APT	Advanced Persistent Threat	CrowdStrike/MITRE	Professional hacker armies often funded by nation-states.
IOC	Indicator of Compromise	Logs/SIEM	Fingerprint evidence (malicious IP/hash) that attacker was in your network.
TTP	Tactics, Techniques & Procedures	MITRE ATT&CK	How attackers operate — what techniques they use.

GROUP 3 — ORGANIZATIONS

Term	Full Name	Type	Simple Function
CISA	Cybersecurity & Infrastructure Security Agency	US Gov	Issues official orders. Manages KEV list.
MITRE	MITRE (proper name)	Research Org	Creates CVE names. Maintains ATT&CK framework.
CERT-In	Indian Computer Emergency Response Team	Indian Gov	Issues advisories. Responds to India cyber incidents.
NIST	National Institute of Standards & Technology	US Gov	Defines good security program standards (NIST CSF).

GROUP 4 — CORE 9 RISK SOURCES

Term	Full Name	RE Tool	Simple Function

VM/Spotlight	Vulnerability Management	CrowdStrike Falcon	Finds old/weak software inside your computers.
EASM	External Attack Surface Management	CrowdStrike/ External	Looks from internet to find open doors.
CNAPP	Cloud Native Application Protection	CrowdStrike Cloud	Protects cloud servers from misconfigs.
OT	Operational Technology	Armis	Protects factory machines and industrial equipment.
VAPT	Vulnerability Assessment & Penetration Testing	External Vendor	Ethical hackers paid to find and report holes.
Threat Intel	Threat Intelligence	External Feed	Live news feed of what bad actors are doing globally.
CERT-In	Indian Computer Emergency Response Team	Indian Gov Agency	Official Indian government advisories on new vulnerabilities.
Bug Bounty	Bug Bounty Program	Internal/External	Paying researchers to responsibly report bugs.
SoC	Security Operations Center	SIEM/SoC Team	24/7 watch center monitoring for live attacks.

GROUP 5 — EXTENDED 5 SECURITY TOOLS

Term	Full Name	RE Tool	Simple Function
NAC	Network Access Control	Forescout/Cisco ISE	The Bouncer. Checks if device is authorized on network.
PAM	Privileged Access Management	CyberArk	The Safe. Holds and controls super-powerful admin passwords.
CASB	Cloud Access Security Broker	Zscaler ZTA/ZIA	Stops users accessing unauthorized or malicious cloud apps.
Firewall	Next-Gen Firewall	Fortiguard	The Castle Wall. Blocks malicious traffic.
Email Sec	Email Security	Google Workspace	Stops phishing and malicious emails before they reach users.

Semantic Gravity · contact@semanticgravity.in · Demo: Gurgaon, May 2026